

# AISM als Referenz für souveräne KI-Infrastruktur

|                      |                                                                                                                                                                                                                                                                                                                                                                   |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Autor                | Markus Oehring                                                                                                                                                                                                                                                                                                                                                    |
| Version              | 1.1 (Entwurf zur Diskussion)                                                                                                                                                                                                                                                                                                                                      |
| Datum                | 05.10.2026                                                                                                                                                                                                                                                                                                                                                        |
| Bezug                | README.md (AISM Reference Stack), AISM-Spezifikation.md (Entwurf 0.2), policy/AISM-Policy-Format.md, conformance/AISM-Konformitaet.md                                                                                                                                                                                                                             |
| Status der Bausteine | Referenzarchitektur und Compose-Profil beschrieben; Policy-Format mit JSON Schema festgelegt; Konformitäts-Testsuite 0.2.0 ausführbar; Governance-Gateway und Orchestrator als Prototypen, im Docker-Konformitäts-Stack mit Mocks statt echter Modelle getestet (alle 37 automatisierten Tests bestanden, Stufe K3 erreicht; Prototyp, keine Produktionsfreigabe) |

**Hinweis:** „AISM“ ist ein Arbeitstitel; die Referenzimplementierung heißt „AISM Reference Stack“. AISM ist ein unabhängiges Projekt und steht in keiner Verbindung zu anderen Produkten ähnlichen Namens oder Zwecks (siehe Abschnitt 3.1). Dieses Papier beschreibt eine Position und einen Plan, kein fertiges Produkt. Es enthält keine Rechtsberatung. Aussagen zu Gesetzen geben den recherchierten Stand vom Oktober 2026 wieder und ersetzen keine Prüfung im Einzelfall.

## INHALT

### Kurzfassung

1. Ausgangslage: Warum KI-Infrastruktur heute schwer zu verantworten ist
2. These: Referenzmodell + Referenzimplementierung + Konformitätstests = überprüfbare Souveränität
3. Was AISM von bestehenden Ansätzen unterscheidet
4. Zielgruppen

5. Regulatorische Relevanz
  6. Nutzen nach Stakeholdern
  7. Open Source und Community-Modell
  8. Roadmap
  9. Risiken und Grenzen
  10. Aufruf zur Mitwirkung
- Quellen

## Kurzfassung

---

Organisationen, die generative KI mit sensiblen Daten einsetzen wollen, stehen vor einer unbequemen Wahl: Entweder sie nutzen Cloud-APIs, deren Datenflüsse sie nur vertraglich, aber nicht technisch kontrollieren, oder sie bauen aus einzelnen Open-Source-Projekten eine eigene Plattform zusammen, deren Sicherheitseigenschaften niemand systematisch geprüft hat. Beides lässt eine zentrale Frage offen: **Wie weist man nach, wohin Daten in einem KI-System fließen und wer darüber entschieden hat?**

AIISM beantwortet diese Frage mit drei Bausteinen, die zusammen mehr leisten als jeder für sich:

1. **AIISM**, ein offenes Referenzmodell, das eine KI-Anfrage als Pipeline aus sieben Stufen (S1–S7) beschreibt und die Stellen festlegt, an denen Policy durchgesetzt und protokolliert wird.
2. **AIISM Reference Stack**, eine quelloffene Referenzimplementierung (Apache 2.0): ein Governance-Gateway und ein Orchestrator als Prototypen sowie eine Compose-Konfiguration, die etablierte Open-Source-Komponenten in die Pipeline einordnet. Sie zeigt, dass sich das Modell mit vorhandenen Bausteinen umsetzen und testen lässt.
3. **Eine Konformitäts-Testsuite** mit drei Stufen (K1 Basic, K2 Governed, K3 Sovereign/Auditable), die prüft, ob eine konkrete Installation die Anforderungen des Modells tatsächlich erfüllt.

Die Kernthese: **Souveränität entsteht nicht durch Feature-Listen, sondern durch Überprüfbarkeit.** Ein Stack ist dann souverän betreibbar, wenn seine Datenflüsse spezifiziert, seine Kontrollpunkte implementiert und beides durch reproduzierbare Tests belegt ist. AIISM will dafür die offene Referenz werden: für Betreiber, für Datenschutzbeauftragte und für Anbieter, die eigene Implementierungen gegen denselben Maßstab prüfen lassen wollen.

## 1. Ausgangslage: Warum KI-Infrastruktur heute schwer zu verantworten ist

---

### 1.1 Fragmentierte Werkzeuge

Ein produktiver KI-Arbeitsplatz besteht aus deutlich mehr als einem Sprachmodell: Inferenzserver, Chat-Oberfläche, Embedding-Modell, Vektordatenbank, Websuche, Workflow-Automatisierung, Identitätsanbindung und Monitoring. Jede dieser Komponenten ist für sich ausgereift, doch sie wurden unabhängig voneinander entwickelt. Konfigurationsformate, Netzwerkannahmen, GPU-Anforderungen und Release-Zyklen unterscheiden sich. Die Verbindung zwischen ihnen entsteht in der Praxis durch individuell geschriebene Umgebungsvariablen, Portfreigaben und API-Brücken. Diese Klebeschicht ist selten dokumentiert, bricht bei Updates und ist genau der Ort, an dem sicherheitsrelevante Entscheidungen fallen, etwa ob eine Chat-Oberfläche das Modell direkt oder über eine Kontrollinstanz anspricht.

### 1.2 Datensouveränität

Für Kanzleien, Steuerberatungen, Arztpraxen, Kliniken, Behörden und viele mittelständische Unternehmen ist nicht die Frage, *ob* KI nützlich ist, sondern *unter welchen Bedingungen* sie mit Mandanten-, Patienten-, Bürger- oder Konstruktionsdaten arbeiten darf. Wer Berufsgeheimnisse wahren muss (z. B. nach § 203 StGB), personenbezogene Daten nach der DSGVO verarbeitet oder Betriebsgeheimnisse schützt, braucht eine belastbare Antwort darauf, wo Daten verarbeitet, gespeichert und protokolliert werden.

## 1.3 Abhängigkeit von Cloud-APIs

Cloud-Modelle sind leistungsfähig und oft der schnellste Einstieg. Sie verlagern aber Kontrolle: über Verfügbarkeit, Preisentwicklung, Modellversionen, Aufbewahrung von Eingaben und den Rechtsraum der Verarbeitung. Das ist kein Argument gegen Cloud-Nutzung an sich, wohl aber gegen eine *unkontrollierte* Nutzung, bei der jede Anwendung eigenständig externe Endpunkte aufruft und niemand einen Gesamtüberblick über die Datenabflüsse hat.

## 1.4 Fehlende nachvollziehbare Datenflüsse

Die grundlegende Lücke ist weder die Modellqualität noch die Hardware, sondern die fehlende Nachvollziehbarkeit. Viele Installationen können nicht verlässlich beantworten:

- Welche Komponente hat welche Daten gesehen, und in welcher Form (Klartext oder maskiert)?
- Welche Anfrage hat das Deployment verlassen, wohin, und auf Grundlage welcher Regel?
- Welches Werkzeug hat ein Modell aufgerufen, mit welchen Parametern, und wer hat das erlaubt?
- Lässt sich das alles nachträglich prüfen, ohne dass das Protokoll selbst zum Datenschutzrisiko wird?

Solange diese Fragen nur durch Dokumentation und Vertrauen beantwortet werden, bleibt jede Zusicherung von „Datenschutz“ oder „Souveränität“ eine Behauptung.

## 2. These: Referenzmodell + Referenzimplementierung + Konformitätstests = überprüfbare Souveränität

Souveränität im Sinne dieses Papiers bedeutet: **Eine Organisation kann selbst bestimmen, belegen und prüfen lassen, wo ihre Daten in einem KI-System verarbeitet werden und welche Regeln dabei gelten.** Das erfordert drei Dinge, die sich gegenseitig absichern.

| Baustein                                              | Funktion                                                                                                                                                                                  | Was er allein nicht leistet                                                |
|-------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Referenzmodell (AISM)</b>                          | Gemeinsame Sprache und normative Anforderungen (MUSS/SOLLTE/KANN nach RFC 2119): Stufen, Schnittstellen, Policy-Durchsetzungspunkte, Audit                                                | Ein Modell beweist nicht, dass eine Installation es einhält.               |
| <b>Referenzimplementierung (AISM Reference Stack)</b> | Zeigt, dass das Modell mit etablierten Open-Source-Komponenten umsetzbar ist, und liefert eine prüfbare Ausgangskonfiguration (signierte Beispiel-Policy, gepinnte Images, Host-Firewall) | Eine Implementierung kann vom Modell abweichen, z. B. durch Konfiguration. |
| <b>Konformitätstests</b>                              | Prüfen eine konkrete Installation automatisiert und reproduzierbar gegen die Anforderungen; erzeugen einen prüffähigen Nachweis                                                           | Tests sind nur so gut wie die Spezifikation, gegen die sie prüfen.         |

Erst die Kombination schließt den Kreis: Das Modell definiert *was* gelten soll, die Implementierung zeigt *wie*, und die Tests belegen, *dass* es in einer bestimmten Installation gilt. Damit verschiebt sich die Diskussion von „Unterstützt das Produkt Datenschutz?“ hin zu „Besteht diese Installation Testfall M-04 (Cloud-Routing standardmäßig deaktiviert) und M-12 (fail-closed bei Ausfall der PII-Erkennung)?“. Diese Frage kann ein IT-Betrieb beantworten, ein Datenschutzbeauftragter nachvollziehen und ein Auditor prüfen.



Abb. 1: AISM-Request-Pipeline (S2 als zentraler Kontrollpunkt) und das Zusammenspiel der drei Bausteine

## 2.1 Das Referenzmodell im Überblick

AISM beschreibt den Weg einer Anfrage in sieben Stufen. Die Nummerierung folgt der Request-Richtung, sodass das Governance-Gateway (S2) sichtbar **vor** jedem Modell-, Index- oder Netzwerkzugriff liegt.

| Stufe | Name                     | Kernaufgabe                                                                              | Referenzkomponenten im AISM Reference Stack     |
|-------|--------------------------|------------------------------------------------------------------------------------------|-------------------------------------------------|
| S1    | UI & Session             | Benutzerinteraktion, Authentifizierung (z. B. OIDC), Streaming-Darstellung               | Open WebUI                                      |
| S2    | Governance-Gateway       | AuthZ, PII-Maskierung, Policy-Entscheidung, Routing lokal/Cloud, Egress-Kontrolle, Audit | AISM-Governance-Gateway (Prototyp)              |
| S3    | Orchestrierung & Agenten | Kontextanreicherung, Tool-Calls über validierendes Gateway                               | AISM-Orchestrator (Prototyp), n8n, optional MCP |
| S4    | Retrieval (RAG)          | Embeddings (separater Endpunkt), Vektorsuche mit Zugriffsfiltern                         | Embedding-Server, Qdrant                        |
| S5    | Grounding                | Websuche mit maskierter Anfrage, als Egress behandelt                                    | SearXNG, Perplexica                             |
| S6    | Inferenz                 | Token-Generierung über OpenAI-kompatible API mit SSE                                     | llama.cpp (Alternativen: vLLM, Ollama)          |
| S7    | Compute                  | Gerätezuordnung an Container, keine Netzwerkschicht                                      | Docker, NVIDIA Container Toolkit/CDI, ROCm      |

Quer dazu liegen Telemetrie und Dashboard, die alle Stufen beobachten, ohne am Request-Pfad teilzunehmen und ohne Prompt-Inhalte zu erfassen. Die Spezifikation legt zehn Policy-Durchsetzungspunkte (PEP-1 bis PEP-10) fest, etwa die Maskierung von Prompts vor jeder Weitergabe, die Allowlist- und Schemaprüfung jedes Tool-Calls und die erneute Prüfung am Egress. Der Grundsatz lautet: **Daten verlassen das Deployment nur über das Governance-Gateway und nur unter Policy.** AISM behauptet ausdrücklich *nicht*, dass grundsätzlich keine Daten das Deployment verlassen; es macht jeden Abfluss entscheidbar und protokolliert.

## 2.2 Policy-as-Code

Regeln, die heute in Konfigurationsdateien oder Köpfen stecken, sollen künftig als versionierter, testbarer Code vorliegen: Welche Rolle darf welches Modell, welche Dokumentensammlung, welches Werkzeug nutzen? Darf eine Datenklasse in die Cloud geroutet werden? Policy-as-Code bringt drei Vorteile: Änderungen sind über Versionskontrolle nachvollziehbar (wer hat wann welche Regel geändert), Regeln lassen sich vor dem Ausrollen automatisiert testen, und Audit-Einträge können auf eine eindeutige Regelversion verweisen. Für die erste Version ist entschieden: AISM verwendet ein **eigenes, deklaratives YAML-Format** mit JSON Schema (`policy/AISM-Policy-Format.md`, `policy.schema.json`), das das Gateway beim Start validiert; ohne gültige Policy leitet es nichts weiter. Eine Abbildung auf eine etablierte Policy-Engine wie Open Policy Agent/Rego bleibt

als optionale Erweiterung möglich, ist aber nicht Voraussetzung. Weiterentwicklungen des Formats sollen im offenen Spezifikationsprozess entschieden werden.

### 2.3 Konformitätsstufen

Die Testsuite (conformance/AISM-Konformitaet.md, Testsuite 0.2.0) gliedert Anforderungen in drei aufeinander aufbauende Stufen K1–K3. Eine Installation erreicht eine Stufe nur, wenn alle MUSS-Tests dieser und der darunterliegenden Stufen **bestanden** sind; übersprungene MUSS-Tests (fehlende Voraussetzung) gelten als nicht erreicht. Fehlgeschlagene SOLLTE-Tests verhindern eine Stufe nicht, werden aber im Bericht ausgewiesen.

| Stufe                         | Leitfrage                                                               | Erforderliche AISM-Kriterien (Spez. §9) und Prüfschwerpunkte                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>K1 Basic</b>               | Ist das Gateway erzwungen und die Schnittstelle interoperabel?          | M-01 (kein Direktzugriff von S1 auf S6, kein Bypass aus dem Client-Netz), M-06 (OpenAI-kompatible API inkl. SSE), M-13 (kein privileged -Container) sowie Authentifizierung am Gateway (Spez. §6.2 Schritt 1); Health-Endpunkt                                                                                                                                                                  |
| <b>K2 Governed</b>            | Setzt das Gateway die Policy nachweisbar durch?                         | K1 und zusätzlich M-02 (PII-Maskierung vor Weitergabe), M-04 (Cloud-Routing standardmäßig aus), M-05 (Audit ohne Klartext-PII), M-07 und M-08 (Tool-Calls, Allowlist und Schemaprüfung), M-09 (RAG-Anfragen nur nach Maskierung über separaten Embedding-Endpunkt), M-11 (abschaltbare Web-Suche), M-12 (fail-closed), M-15 (gültige Policy geladen, Version und Digest in jedem Audit-Eintrag) |
| <b>K3 Sovereign/Auditable</b> | Kann die Organisation den Betrieb unabhängig belegen und prüfen lassen? | K2 und zusätzlich, in K3 als Pflicht: S-02 (manipulationserkennbares Audit, Hash-Kette), S-07 (Images per Digest gepinnt, Modell-Prüfsummen), S-10 (Trace-IDs Ende-zu-Ende), S-11 (signierte Policy-Versionen), S-13 (Nachweis je Cloud-Egress)                                                                                                                                                 |

Wichtig: Die Stufen beschreiben **technische Eigenschaften einer Installation**, nicht die Rechtskonformität einer Organisation. Ein K3-Bericht ist ein Beleg, den Datenschutz, Informationssicherheit und Revision verwenden können, aber kein Zertifikat im Sinne eines Gesetzes.

**Stand 05.10.2026:** Ein Lauf im Docker-Konformitäts-Stack gegen die Prototypen von Gateway und Orchestrator (mit Mocks statt echter Modelle, Test-IdP und Test-Signaturschlüssel) bestand alle 37 automatisierten Tests von K1 bis K3. Dazu gehören die signierte Policy samt Ablehnung manipulierter Fassungen, per Digest gepinnte Images und ein Cloud-Fallback-Szenario mit Egress-Nachweis. Nicht abgedeckt sind die Prüfsummen der Modelldateien, Open WebUI und echte Modelle auf GPU. Der Lauf zeigt die Prüfbarkeit des Ansatzes; er ist kein Nachweis für eine produktive Installation.

### 3. Was AISM von bestehenden Ansätzen unterscheidet

Der Markt für lokale und private KI wächst, und es gibt gute Lösungen. AISM positioniert sich nicht gegen einzelne Produkte, sondern gegenüber **Kategorien** von Ansätzen:

| Kategorie                                                   | Typische Stärke                              | Typische Lücke aus Sicht überprüfbarer Souveränität                                                                                               |
|-------------------------------------------------------------|----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Cloud-KI-Dienste</b> (API oder SaaS)                     | Höchste Modellleistung, kein eigener Betrieb | Datenfluss wird vertraglich zugesichert, aber nicht im eigenen Haus technisch durchgesetzt oder geprüft                                           |
| <b>All-in-one-Desktop- oder Server-Pakete</b> für lokale KI | Sehr einfacher Einstieg, gute Oberfläche     | Governance ist meist eine Funktion der jeweiligen Anwendung; ein anwendungsübergreifender Kontrollpunkt und ein offener Prüfmaßstab fehlen häufig |

| Kategorie                                          | Typische Stärke                           | Typische Lücke aus Sicht überprüfbarer Souveränität                                                               |
|----------------------------------------------------|-------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>Selbst zusammengestellte Open-Source-Stacks</b> | Maximale Flexibilität, keine Lizenzkosten | Die Integration ist individuell, Sicherheitseigenschaften hängen von Einzelpersonen ab und sind kaum vergleichbar |
| <b>Proprietäre Enterprise-KI-Plattformen</b>       | Integrierter Support, Funktionsumfang     | Prüfkriterien sind meist herstellerdefiniert; Wechsel einzelner Komponenten ist eingeschränkt                     |

Die Unterscheidungsmerkmale von AISM sind daher strukturell:

- **Spezifikation vor Produkt.** AISM ist ein offenes Modell mit normativen Anforderungen. Der AISM Reference Stack ist *eine* Implementierung davon, nicht die einzige mögliche. Andere Anbieter können konforme Implementierungen bauen.
- **Ein zentraler Kontrollpunkt statt verteilter Einstellungen.** Maskierung, Policy, Routing und Audit liegen im Governance-Gateway (S2) und gelten für alle Clients gleichermaßen: Chat-Oberfläche, Agenten, Workflows und Suchkomponenten.
- **Ausführungshoheit außerhalb des Modells.** Ein Modell kann Tool-Aufrufe nur *vorschlagen*. Ausgeführt wird erst nach Allowlist- und Schemaprüfung; Ergebnisse werden maskiert und protokolliert.
- **Lokal zuerst, nicht ausschließlich lokal.** Hybridbetrieb ist vorgesehen, aber jeder Cloud-Aufruf ist eine explizite, protokollierte Policy-Entscheidung, die standardmäßig deaktiviert ist.
- **Austauschbare Komponenten über Standardschnittstellen.** OpenAI-kompatible API, SSE, JSON-RPC/MCP, Qdrant REST/gRPC: Komponenten lassen sich wechseln, solange die Schnittstellenverträge eingehalten werden. Die Testsuite prüft genau das.
- **Nachweis statt Versprechen.** Konformitätsstufen machen Eigenschaften messbar und vergleichbar, auch über Implementierungen hinweg.
- **Ehrliche Grenzen im Modell selbst.** Die Spezifikation benennt offene Punkte (z. B. Fehlerraten der Namenserkennung) und enthält bewusst keine Leistungsversprechen.

### 3.1 Verwandte Projekte

Mehrere quelloffene Projekte bündeln lokale Inferenz, Chat, Retrieval und Automatisierung, mit unterschiedlichem Schwerpunkt, etwa einfache Installation oder eine einzelne Anwendung. Beispiele ohne Anspruch auf Vollständigkeit und ohne Wertung: **Harbor** (CLI- und Compose-Setup für lokale LLM-Werkzeuge), das **n8n Self-hosted AI Starter Kit** (n8n, Ollama und Qdrant per Docker Compose), **LocalAI** (OpenAI-kompatibler lokaler Inferenzserver), **AnythingLLM** (Anwendung für die Arbeit mit Dokumenten) und **Osmantic ODS** (Osmantic Deployment System, ein quelloffenes Deployment-System für lokale und hybride KI-Dienste).

AISM ist von all diesen Projekten **unabhängig**: Es besteht keine Verbindung, Partnerschaft oder Empfehlung, und es werden weder Code noch Texte übernommen. AISM ist kein Deployment-Werkzeug, sondern ein Referenzmodell mit Prüfmaßstab. Grundsätzlich ließe sich jeder dieser Stacks gegen die Konformitätsstufen prüfen. Produktnamen gehören den jeweiligen Rechteinhabern.

## 4. Zielgruppen

AISM richtet sich an Organisationen, für die Vertraulichkeit und Nachvollziehbarkeit Voraussetzung für den KI-Einsatz sind.

| Zielgruppe                            | Typische Anforderungen                                    | Beitrag von AISM                                                                                                               |
|---------------------------------------|-----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| <b>Steuerberatungen und Kanzleien</b> | Berufsgeheimnis, Mandantendaten, Akten- und Fristenarbeit | Lokale Inferenz als Standard, Cloud nur nach Freigabe; Retrieval mit Zugriffsfiltern je Mandat; protokollierte Werkzeugnutzung |

| Zielgruppe                       | Typische Anforderungen                                                                                     | Beitrag von AISM                                                                                                                                                                                 |
|----------------------------------|------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Öffentliche Verwaltung</b>    | Datenhoheit, Vergaberecht, Nachvollziehbarkeit von Verwaltungshandeln, Informationssicherheit              | Offene Spezifikation und Apache-2.0-Lizenz unterstützen herstellerunabhängige Ausschreibungen; Konformitätsstufen als prüfbare Anforderung                                                       |
| <b>Gesundheitswesen</b>          | Besonders schutzwürdige Gesundheitsdaten (Art. 9 DSGVO), Schweigepflicht, hohe Verfügbarkeitsanforderungen | Air-Gap-fähiger Betrieb, Egress vollständig abschaltbar, Audit ohne Klartextdaten                                                                                                                |
| <b>Mittelstand</b>               | Schutz von Know-how und Konstruktionsdaten, begrenzte IT-Ressourcen, planbare Kosten                       | Vorgeprüfte Referenzkonfiguration statt Eigenintegration, Betrieb auf vorhandener Hardware; Konformitätsbericht als Nachweis gegenüber Kunden und Prüfern; Cloud-Nutzung begrenzt und auswertbar |
| <b>Forschung und Hochschulen</b> | Reproduzierbarkeit, Forschungsdaten, Drittmittelaufgaben, Offenheit                                        | Gepinnte Versionen, dokumentierte Pipeline, offene Spezifikation als Basis für eigene Experimente und Lehre                                                                                      |

## 5. Regulatorische Relevanz

Dieser Abschnitt ordnet ein, **wo** AISM bei regulatorischen Anforderungen technisch unterstützen kann. Er trifft keine Aussage darüber, dass ein Einsatz rechtskonform ist. Diese Bewertung hängt vom konkreten Verarbeitungszweck, den Daten, der Organisation und dem Einsatzkontext ab und bleibt Aufgabe der Verantwortlichen und ihrer Beratung.

### 5.1 DSGVO

| Anforderung                                                                                      | Wie AISM technisch unterstützt                                                                                                                                                                 | Grenze                                                                                           |
|--------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Datenminimierung</b> (Art. 5 Abs. 1 lit. c)                                                   | PII-Maskierung vor jeder Weitergabe an Modelle, Indizes und externe Ziele (PEP-2, PEP-8); Audit mit Zählern statt Klartext; Telemetrie ohne Prompt-Inhalte                                     | Maskierung erkennt nicht jedes personenbezogene Datum; Fehlerraten müssen gemessen werden        |
| <b>Datenschutz durch Technikgestaltung und datenschutzfreundliche Voreinstellungen</b> (Art. 25) | Cloud-Routing standardmäßig aus (M-04), fail-closed bei Ausfall der Erkennung (M-12), Kontrollpunkt im Request-Pfad statt nachträglicher Kontrolle                                             | Voreinstellungen müssen im Betrieb beibehalten werden; K2/K3-Tests machen Abweichungen sichtbar  |
| <b>Verzeichnis von Verarbeitungstätigkeiten</b> (Art. 30)                                        | Das AISM-Stufenmodell beschreibt Datenkategorien, Empfänger (lokal/Cloud/Websuche) und Kontrollpunkte strukturiert; daraus lassen sich Einträge ableiten                                       | Das Verzeichnis selbst bleibt organisatorische Pflicht des Verantwortlichen                      |
| <b>Sicherheit der Verarbeitung / TOM</b> (Art. 32)                                               | Zugriffskontrolle (OIDC, Policies), Pseudonymisierung durch Platzhalter, Egress-Kontrolle, manipulationserkennbares Audit, Härtung (keine <code>privileged</code> -Container, gepinnte Images) | TOM umfassen auch organisatorische Maßnahmen, Schulung, Notfallkonzepte und physische Sicherheit |

Zwei Präzisierungen sind wichtig. Erstens ist die Maskierung mit reversiblen Platzhaltern im Sinne der DSGVO eine **Pseudonymisierung** (Art. 4 Nr. 5), keine Anonymisierung: Maskierte Daten bleiben grundsätzlich personenbezogen. Zweitens ersetzt AISM weder eine Datenschutz-Folgenabschätzung (Art. 35), wo sie

erforderlich ist, noch Verträge zur Auftragsverarbeitung (Art. 28) oder die Prüfung von Drittlandübermittlungen (Art. 44 ff.), wenn Cloud-Routing aktiviert wird. Es liefert aber die technische Dokumentation und die Belege, die solche Prüfungen erleichtern.

## 5.2 EU AI Act

Der AI Act (Verordnung (EU) 2024/1689) gilt gestaffelt. Durch den „Digital Omnibus on AI“ (Verordnung (EU) 2026/1744, in Kraft seit 27.07.2026) wurden die Fristen für Hochrisiko-KI-Systeme verschoben. Stand Oktober 2026 gilt nach Angaben der EU-Kommission:

| Datum      | Anwendungsbeginn (Auszug)                                                                                                                            |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| 02.02.2025 | Verbotene Praktiken, KI-Kompetenz (Art. 4; durch den Omnibus inzwischen vereinfacht)                                                                 |
| 02.08.2025 | Regeln für KI-Modelle mit allgemeinem Verwendungszweck (GPAI), Governance-Strukturen                                                                 |
| 02.08.2026 | Großteil der Verordnung, insbesondere Transparenzpflichten (Art. 50); Beginn der Durchsetzung                                                        |
| 02.12.2026 | Neue Verbote (u. a. nicht einvernehmliche intime Deepfakes); Übergangsfrist für Art. 50 Abs. 2 bei vor dem 02.08.2026 in Verkehr gebrachten Systemen |
| 02.12.2027 | Pflichten für Hochrisiko-KI-Systeme nach Anhang III (zuvor 02.08.2026)                                                                               |
| 02.08.2028 | Pflichten für Hochrisiko-KI in Produkten nach Anhang I (zuvor 02.08.2027)                                                                            |

Ob ein konkreter Einsatz eines AISM-konformen Stacks überhaupt unter die Hochrisiko-Regeln fällt, hängt vom **Verwendungszweck** ab, nicht von der Technik. Ein interner Rechercheassistent ist anders einzuordnen als ein System, das etwa im Personalbereich Entscheidungen über Bewerbungen vorbereitet (Anhang III). AISM **unterstützt** dabei, typische technische Anforderungen umzusetzen und nachzuweisen:

- **Protokollierung und Rückverfolgbarkeit:** Für Hochrisiko-Systeme verlangt Art. 12 die technische Möglichkeit automatischer Ereignisprotokolle; Betreiber („Deployer“) müssen unter ihrer Kontrolle stehende Protokolle nach Art. 26 Abs. 6 mindestens sechs Monate aufbewahren, soweit nichts anderes bestimmt ist. Das AISM-Audit-Konzept (jede Policy-Entscheidung, jeder Tool-Call, jedes Egress-Ereignis, manipulationserkennbar gespeichert) unterstützt bei der Umsetzung solcher Pflichten. Es ersetzt nicht die Pflichten des Anbieters eines Hochrisiko-Systems.
- **Transparenz:** Art. 50 verpflichtet u. a. dazu, Personen darüber zu informieren, dass sie mit einem KI-System interagieren, und bestimmte synthetische Inhalte zu kennzeichnen. Da S1 und S2 jede Ausgabe durchlaufen, bietet die Architektur einen definierten Ort für Hinweise und Kennzeichnungen. Ob und wie eine Pflicht im Einzelfall greift, ist rechtlich zu prüfen.
- **Menschliche Aufsicht und Kontrolle von Aktionen:** Die Bestätigungspflicht für schreibende Tools (S-03) und die begrenzte Zahl von Tool-Runden (S-09) unterstützen beim Entwurf von Aufsichtsmaßnahmen.

AISM erfüllt den AI Act nicht „automatisch“, und eine Konformitätsstufe ist keine Konformitätsbewertung im Sinne der Verordnung.

## 5.3 NIS2, BSI IT-Grundschutz und C5 (Einordnung)

Diese Rahmenwerke werden hier nur als **Bezugspunkte** genannt; eine Zuordnung von AISM-Kriterien zu deren Anforderungen ist Teil der Roadmap und noch nicht erfolgt.

- **NIS2:** In Deutschland ist das NIS-2-Umsetzungsgesetz am 06.12.2025 in Kraft getreten (BGBl. 2025 I Nr. 301). Betroffene Einrichtungen müssen Risikomanagementmaßnahmen umsetzen. Eine KI-Plattform ist dann ein Teil der zu schützenden IT; Härtung, Protokollierung und kontrollierter Egress können in solche Maßnahmen einfließen.
- **BSI IT-Grundschutz:** Das BSI entwickelt den IT-Grundschutz zu „Grundschutz++“ mit maschinenlesbaren Anforderungen weiter; die Methodik soll nach BSI-Planung auf der it-sa 2026

veröffentlicht werden. Maschinenlesbare Anforderungen passen gut zum Ansatz maschinenprüfbarer Konformitätstests; eine Abbildung ist eine mögliche spätere Erweiterung.

- **BSI C5:** Der Kriterienkatalog für Cloud-Dienste liegt seit 2026 als C5:2026 vor, erstmals auch maschinenlesbar. C5 adressiert Cloud-Anbieter und ist für lokal betriebene Installationen nicht unmittelbar einschlägig, kann aber für Betreiber relevant sein, die einen AISM-konformen Stack als Dienst für Dritte anbieten oder Cloud-Routing zu externen Anbietern prüfen.

## 6. Nutzen nach Stakeholdern

| Stakeholder                   | Zentrale Frage                                                         | Nutzen durch AISM                                                                                                                                                                                                                                                      |
|-------------------------------|------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Geschäftsführung</b>       | „Können wir KI einsetzen, ohne unkalkulierbare Risiken einzugehen?“    | Klare Entscheidungsgrundlage: definierte Konformitätsstufe als Zielvorgabe; Cloud-Nutzung als bewusste, protokollierte Entscheidung statt Schatten-IT; geringere Abhängigkeit von einzelnen Anbietern durch offene Lizenz und austauschbare Komponenten                |
| <b>IT-Betrieb</b>             | „Wie betreiben wir das stabil und sicher?“                             | Gepinnte und reproduzierbar gebaute Images, signierte Policy mit Rückfall auf die letzte gültige Fassung; Fehlersuche entlang der Stufen („Fehler ab S3“) mit Trace-IDs; automatisierte Tests nach Updates zeigen, ob Sicherheitseigenschaften erhalten geblieben sind |
| <b>Datenschutzbeauftragte</b> | „Wohin fließen die Daten, und wie belege ich das?“                     | Dokumentiertes Datenflussmodell mit benannten Kontrollpunkten; Audit ohne Klartext-PII; Prüfbericht als Beleg für Datenschutz-Folgenabschätzung, Verarbeitungsverzeichnis und TOM-Dokumentation                                                                        |
| <b>Entwickler</b>             | „Wie baue ich Anwendungen, ohne Governance jedes Mal neu zu erfinden?“ | Eine OpenAI-kompatible Schnittstelle für alle Modelle; Policy, Maskierung und Audit kommen vom Gateway; Tools über n8n oder MCP mit klaren Verträgen; Testsuite als Regressionsnetz in CI                                                                              |

## 7. Open Source und Community-Modell

### 7.1 Lizenz

AISM (Spezifikation, Policy-Format, Testsuite und AISM Reference Stack) wird unter der **Apache License 2.0** veröffentlicht. Die Lizenz erlaubt kommerzielle Nutzung, Veränderung und Weitergabe, enthält eine ausdrückliche Patentlizenz der Beitragenden und ist in Unternehmen und Verwaltung gut etabliert. Gebündelte Komponenten behalten ihre eigenen Lizenzen; diese sind vor einer Weitergabe von Images zu prüfen.

Für die AISM-Spezifikation und die Testsuite wird ebenfalls eine offene Lizenz angestrebt, damit Dritte eigene Implementierungen bauen und prüfen können, ohne Erlaubnis einholen zu müssen.

### 7.2 Governance der Spezifikation

Ein Referenzmodell ist nur dann glaubwürdig, wenn es nicht im alleinigen Interesse einer einzelnen Implementierung weiterentwickelt wird. Vorgeschlagen werden:

- **Trennung von Spezifikation und Implementierung:** eigenes Repository, eigene Versionierung (semantisch, mit Änderungsprotokoll) und klar gekennzeichnete normative Texte.
- **Offener Änderungsprozess:** Änderungsvorschläge als öffentliche Requests for Comments mit Kommentierungsfrist; Entscheidungen werden begründet dokumentiert.

- **Technischer Lenkungskreis:** mittelfristig mit Vertretern aus Anwendern (z. B. regulierte Branchen, Verwaltung), Implementierern und Wissenschaft, damit keine Einzelpartei dominiert.
- **Mehrere Implementierungen als Ziel:** Eine Anforderung gilt erst als ausgereift, wenn sie in mehr als einer Implementierung umgesetzt und getestet ist.
- **Langfristige Perspektive:** Eine Überführung in eine neutrale Trägerstruktur (z. B. Stiftung oder etablierte Open-Source-Foundation) wird geprüft, sobald die Community dafür groß genug ist.

## 7.3 Zertifizierungsidee

Die Testsuite ermöglicht zunächst **Selbstbewertung**: Betreiber führen sie aus und erhalten einen maschinenlesbaren Bericht. Darauf aufbauend ist ein mehrstufiges Modell denkbar:

1. **Selbsterklärung** mit veröffentlichtem Testbericht (Version der Spezifikation, der Testsuite und der getesteten Installation).
2. **Unabhängige Prüfung** durch Dritte, die die Testsuite in der Zielumgebung ausführen und die organisatorischen Nachweise sichten.
3. **Kennzeichnung**, z. B. „AISM K2 Governed (Spec 1.0)“, mit Gültigkeitsdauer und Bezug auf eine konkrete Version.

Eine Zertifizierung würde ausschließlich technische Eigenschaften gegenüber der AISM-Spezifikation bestätigen. Sie wäre weder eine gesetzliche Zertifizierung noch ein Ersatz für Prüfungen nach DSGVO, AI Act, NIS2 oder BSI-Standards. Ob und durch wen eine Prüfung angeboten wird, soll im offenen Spezifikationsprozess entschieden werden.

## 8. Roadmap

Die Roadmap beschreibt Phasen und Ergebnisse, keine festen Termine. Die Reihenfolge ergibt sich aus Abhängigkeiten: Ohne Gateway keine Governance-Tests, ohne Tests keine Zertifizierung.

| Phase                                           | Schwerpunkt                  | Ergebnisse                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------------------------|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>0 – Fundament</b><br>(erledigt)              | Architektur und Modell       | README und Referenz-Compose; AISM-Spezifikation Entwurf 0.2; Policy-Format mit JSON Schema; dieses Positionierungspapier                                                                                                                                                                                                                                                                      |
| <b>1 – Governance-Kern</b> (Prototyp vorhanden) | Gateway als Kontrollpunkt    | Erledigt als Prototyp: Governance-Gateway (OpenAI-kompatibles Passthrough mit SSE, PII-Maskierung mit reversiblen Platzhaltern, YAML-Policy mit Schema- und Semantikprüfung, JSONL-Audit mit Hash-Kette), Orchestrator-Stub, Compose-Profil mit Gateway-Pflicht für die UI und Referenz-Host-Firewall. Erledigt: OIDC-Anbindung für Gruppenrollen (gegen Test-IdP). Offen: Härtung, aism -CLI |
| <b>2 – Prüfbarkeit</b><br>(begonnen)            | Testsuite und Policy-as-Code | Erledigt: Testsuite für K1–K3 mit maschinenlesbarem Bericht und Badge; Policy-Sprache entschieden (eigenes Schema, OPA-Abbildung optional). Erledigt: Lauf im Docker-Konformitäts-Stack; erste Messung der PII-Erkennung auf synthetischen deutschen Daten. Offen: Lauf in CI; Messung mit realitätsnahen Daten und Englisch; AISM-Spezifikation 1.0 nach öffentlicher Kommentierung          |
| <b>3 – Souveränität &amp; Audit</b>             | K3 und Betriebsnachweise     | Hash-verkettetes Audit (im Prototyp vorhanden), WORM-Ziel, Air-Gap-Profil, signierte Policies mit Prüfung im Gateway, per Digest gepinnte Artefakte und automatisierte K3-Szenarien (im Prototyp erledigt); Schlüsselrotation, Modell-Prüfsummen; Leitfaden für Datenschutzbeauftragte (Ableitung von Verarbeitungsverzeichnis und TOM aus dem Modell)                                        |

| Phase         | Schwerpunkt            | Ergebnisse                                                                                                                                                                                                             |
|---------------|------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 4 – Ökosystem | Breite und Neutralität | Zweite unabhängige Implementierung bzw. Komponentenprofile (vLLM, Milvus, LibreChat); Abbildung auf NIS2/Grundschutz++ als Orientierungshilfe; Pilot der unabhängigen Prüfung; Entscheidung über neutrale Trägerschaft |

## 9. Risiken und Grenzen

Ein Positionierungspapier, das Überprüfbarkeit fordert, muss seine eigenen Schwächen offenlegen.

- **PII-Erkennung ist fehleranfällig.** Insbesondere Namenserkennung in deutschen Texten erzeugt sowohl Fehlalarme als auch übersehene Daten. Maskierung reduziert Risiken, beseitigt sie aber nicht. Fehlerraten werden gemessen und veröffentlicht, nicht behauptet.
- **Lokale Modelle sind nicht für jede Aufgabe gleichwertig.** Je nach Hardware und Modellgröße können Qualität und Geschwindigkeit hinter großen Cloud-Modellen zurückbleiben. Hybridrouting mildert das, verschiebt aber die Abwägung zur Policy.
- **Konformität ist eine Momentaufnahme.** Ein bestandener Test belegt den Zustand zum Prüfzeitpunkt. Konfigurationsänderungen, Updates oder Eingriffe am Gateway vorbei können ihn entwerten. Regelmäßige, automatisierte Wiederholung ist daher Teil des Konzepts.
- **Spezifikation in frühem Stadium.** AISM liegt als Entwurf 0.2 vor. Gateway und Orchestrator existieren nur als Prototypen; die Testsuite lief bisher nur lokal gegen einen Mock statt gegen echte Modelle und nicht im Docker-Referenzstack. Offen sind u. a. die Übernahme von Gruppen aus der Chat-Oberfläche (das von Open WebUI weitergeleitete Token enthält keine Gruppen), gemessene Fehlerraten der PII-Erkennung, Policy-Signaturen und die native Inferenz auf Apple Silicon.
- **Abhängigkeit von Upstream-Projekten.** Der AISM Reference Stack integriert Komponenten mit eigenen Release-Zyklen und API-Änderungen (z. B. versionsabhängige Such-APIs). Das erfordert Pflege und Kompatibilitätstests.
- **Prompt-Injection und Agentenrisiken.** Inhalte aus Dokumenten, Websuche und Tool-Ergebnissen können Modelle manipulieren. AISM begrenzt die Auswirkungen (keine Tool-Ausführung ohne Prüfung, Kennzeichnung als nicht vertrauenswürdige Daten), kann das Problem aber nicht grundsätzlich lösen.
- **Organisatorische Pflichten bleiben.** Technik kann Rollenkonzepte, Schulung, Löschfristen, Verträge und rechtliche Bewertung nicht ersetzen.
- **Glaubwürdigkeit und Neutralität.** Solange die Spezifikation im Wesentlichen von einem Initiator getragen wird, besteht das Risiko, als Produktmarketing wahrgenommen zu werden. Die Governance-Vorschläge in Abschnitt 7 adressieren das, wirken aber erst mit wachsender Beteiligung.
- **Betriebsaufwand.** Eigene KI-Infrastruktur braucht Hardware, Know-how und Verantwortlichkeit im Haus. Für sehr kleine Organisationen kann ein betreuter Betrieb durch Dienstleister sinnvoller sein; auch dafür bietet die Testsuite einen gemeinsamen Maßstab.

## 10. Aufruf zur Mitwirkung

AISM soll eine Referenz werden, die nicht einer Organisation gehört, sondern von denen getragen wird, die sie brauchen. Dafür suche ich Mitstreiter:

- **Anwender aus regulierten Branchen** (Kanzleien, Steuerberatungen, Verwaltung, Gesundheitswesen, Mittelstand, Forschung): Bringen Sie Ihre Anforderungen ein, testen Sie frühe Versionen in nicht produktiven Umgebungen und sagen Sie uns, welche Nachweise Ihre Prüfer tatsächlich verlangen.
- **Datenschutz- und Informationssicherheitsfachleute:** Kommentieren Sie die Spezifikation, insbesondere die Policy-Durchsetzungspunkte, das Audit-Konzept und die Abgrenzung zu rechtlichen Anforderungen.

- **Entwickler und Integratoren:** Beteiligen Sie sich am Governance-Proxy, an PII-Detektoren für deutsche Texte, an Testfällen der Konformitätssuite oder an Profilen für alternative Komponenten.
- **Hochschulen und Forschungseinrichtungen:** Unterstützen Sie die Messmethodik (PII-Erkennung, Leistungsmessung) und unabhängige Evaluationen.
- **Anbieter und Dienstleister:** Bauen Sie eigene AISM-konforme Implementierungen oder Betriebsangebote und helfen Sie, die Spezifikation an der Praxis zu schärfen.

Der nächste konkrete Schritt ist die öffentliche Kommentierung der AISM-Spezifikation und die gemeinsame Schärfung der Testfälle für K1 und K2. Wer mitwirken möchte, kann sich direkt an mich wenden.

**Markus Oehring**

## Quellen

---

Alle Quellen abgerufen bzw. geprüft am 05.10.2026.

1. Verordnung (EU) 2024/1689 (KI-Verordnung, AI Act), EUR-Lex: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>
2. Verordnung (EU) 2026/1744 (Digital Omnibus on AI), EUR-Lex: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex%3A32026R1744>
3. Europäische Kommission, „AI Omnibus enters into force“ (27.07.2026): <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force>
4. AI Act Service Desk der Europäischen Kommission, „Timeline for the Implementation of the EU AI Act“: <https://ai-act-service-desk.ec.europa.eu/en/ai-act/timeline/timeline-implementation-eu-ai-act>
5. Art. 26 AI Act (Pflichten der Betreiber von Hochrisiko-KI-Systemen), konsolidierte Lesefassung (inoffiziell): <http://artificialintelligenceact.eu/article/26/>
6. Verordnung (EU) 2016/679 (DSGVO), EUR-Lex: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
7. NIS-2-Umsetzungsgesetz, BGBl. 2025 I Nr. 301 vom 05.12.2025: <https://www.recht.bund.de/bgbl/1/2025/301/VO.html>
8. BSI, Pressemitteilung „Sicheres Cloud-Computing: BSI veröffentlicht C5:2026“ (07.04.2026): [https://www.bsi.bund.de/DE/Service-Navi/Presse/Pressemitteilungen/Presse2026/260407\\_C5\\_Cloud\\_Computing.html](https://www.bsi.bund.de/DE/Service-Navi/Presse/Pressemitteilungen/Presse2026/260407_C5_Cloud_Computing.html)
9. BSI, Grundschutz++: [https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Grundschutz-in-der-Informationssicherheit/Grundschutz-Plus-Plus/grundschutz-plus-plus\\_node.html](https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Grundschutz-in-der-Informationssicherheit/Grundschutz-Plus-Plus/grundschutz-plus-plus_node.html)
10. Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>
11. RFC 2119, „Key words for use in RFCs to Indicate Requirement Levels“: <https://www.rfc-editor.org/rfc/rfc2119>
12. Interne Dokumente: `README.md` (AISM Reference Stack), `AISM-Spezifikation.md` (Entwurf 0.2), `policy/AISM-Policy-Format.md`, `conformance/AISM-Konformitaet.md` (Entwurf 0.2, Testsuite 0.2.0), Stand jeweils 05.10.2026

*Hinweis zur Benennung:* Konformitätsstufen heißen **K1–K3** (K1 Basic, K2 Governed, K3 Sovereign/Auditable), Pipeline-Stufen des Referenzmodells **S1–S7**, die Komponentengruppen eines früheren README-Entwurfs **L1–L7**. Die Kriterien der Spezifikation tragen die Präfixe **M-** (MUSS), **S-** (SOLLTE) und **O-** (KANN, O-01 bis O-03); Testfälle der Suite heißen `AISM-K<Stufe>-<Nr.>` (z. B. `AISM-K2-03`).